

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege (Currently, all Botium Toys employees have unrestricted access to internally stored data, therefore, the principle of least privilege has not been implemented.)
☐	☒	Disaster recovery plans (There are no disaster recovery plans currently in place)
☒	☐	Password policies (A password policy exists, but it is weak and outdated)
☐	☒	Separation of duties (Separation of duties has not been implemented)
☒	☐	Firewall (A firewall is installed and blocks traffic using security rules)
☐	☒	Intrusion detection system (IDS) (The IT department has not installed an IDS)
☐	☒	Backups (There are no backups of critical data)
☒	☐	Antivirus software (Antivirus software is installed and regularly monitored)
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems (Legacy systems are maintained, but there is no regular schedule or clear process)
☐	☒	Encryption (Encryption is not currently used to ensure confidentiality of customers' credit card information)
☐	☒	Password management system (There is no centralized password)

management system)

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | Locks (offices, storefront, warehouse) (Physical locations have sufficient locks) |
| ☒ | ☐ | Closed-circuit television (CCTV) surveillance (CCTV surveillance is installed and up to date) |
| ☒ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) (Fire detection and prevention systems are functioning) |

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information. (All employees may be able to access cardholder data)
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. (Credit card data is handled internally but not adequately secured due to lack of encryption and access controls)
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data. (Data encryption procedures have not been implemented)
☐	☒	Adopt secure password management policies. (Password requirements are weak and no management system exists)

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured. (The company does not currently use encryption to better ensure the confidentiality of customers' financial information)
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. (A 72-hour breach notification plan is in place)
☐	☒	Ensure data is properly classified and inventoried. (Current assets have been inventoried/listed, but not classified)
☐	☒	Enforce privacy policies, procedures, and processes to properly document and maintain data. (Privacy policies and procedures are established and enforced)

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.